

UNIVERSITÀ DEGLI STUDI DI SALERNO

DIPARTIMENTO DI INGEGNERIA DELL'INFORMAZIONE ED
ELETTRICA E MATEMATICA APPLICATA



Project Work

Membri del gruppo

Nome e Cognome	Matricola	E-mail	WP Responsabile
Leonardo Lo Sapio	0622702053	l.losapio1@studenti.unisa.it	WP2
Palma Orlando	0622702433	p.orlando8@studenti.unisa.it	WP1
Andrea Scala	0622702346	a.scala31@studenti.unisa.it	WP3

Indice

WP1: MODELLO	3
Attori del sistema	3
Possibili attaccanti del sistema	4
Proprietà	6
WP2: SOLUZIONE.....	8
Panoramica generale di funzionamento	8
Generazione e utilizzo delle credenziali	8
Supposizioni.....	8
Richiesta firma digitale alla CIE	9
Richiesta credenziali ad un'autorità	10
Generazione delle credenziali	11
Richiesta di un servizio generico da parte dell'utente.....	13
SECONDA PARTE.....	15
WP3: ANALISI	16
Confidenzialità	16
Integrità	17
Trasparenza	18
Efficienza.....	19
Grafico Radar	19
WP4: IMPLEMENTAZIONE E PRESTAZIONI	20

WP1: MODELLO

In questa parte del work project definiremo gli attori onesti coinvolti nel sistema, analizzandone obiettivi e funzionalità. Gli attori onesti sono quegli individui o entità che agiscono in conformità con le regole e le politiche stabilite, cercando di raggiungere i loro obiettivi senza compromettere l'integrità del sistema.

Inoltre, verranno esaminati i possibili avversari che potrebbero essere interessati a compromettere il sistema, analizzandone le risorse e le motivazioni alla base delle loro azioni. Tale analisi ci consentirà di identificare gli attacchi che il sistema potrebbe subire e di comprendere quali misure di sicurezza dovranno essere adottate per contrastarli.

Una volta compreso il contesto in cui il sistema opera, verranno specificate le proprietà di sicurezza che si vorrebbero preservare in presenza di attacchi.

Attori del sistema

In questo scenario ci sono diversi attori coinvolti nel sistema, ognuno con obiettivi e funzionalità specifiche. Di seguito sono elencati tali attori:

- **Utenti:** sono coloro che desiderano accedere ai servizi qualificati tramite l'utilizzo di credenziali. Sono inoltre responsabili della gestione fisica dei propri documenti d'identità.
- **Server:** servizio qualificato, ossia ristretto ai possessori di specifiche credenziali. Un utente può accedere a un servizio se il server riconosce come affidabile le autorità che hanno rilasciato le credenziali possedute dall'utente e se queste soddisfano il requisito di accesso. Se un servizio richiede più credenziali, non è possibile che più utenti combinino le loro credenziali per accedere al servizio.
- **Autorità:** autorità riconosciuta per il rilascio di credenziali. Per ottenere una credenziale, l'utente deve rivolgersi a questo servizio tramite l'utilizzo della propria CIE. Nota: con questo identificativo intendiamo rappresentare tutte le autorità riconosciute per il rilascio di credenziali.
- **Ufficio Anagrafe:** è l'ente responsabile della gestione dei dati anagrafici della popolazione. La sua funzione principale è il rilascio delle Carte d'Identità Elettroniche (CIE) agli utenti che ne fanno richiesta. L'ufficio anagrafe garantisce la sicurezza dei documenti rilasciati all'utente.
- **IPZS:** o Istituto Poligrafico e Zecca dello Stato, è l'ente incaricato della produzione e generazione delle Carte d'Identità Elettroniche (CIE) per ogni utente che ne fa richiesta tramite gli Uffici Anagrafe. L'IPZS garantisce la sicurezza dei documenti emessi, utilizzando tecnologie avanzate per prevenire contraffazioni. Inoltre, figura come Certification Authority.
- **Giustizia:** è l'entità a cui ci si rivolge nei casi in cui è necessario aiuto durante attacchi particolarmente gravi al sistema. Essa interviene per garantire l'applicazione della legge e la tutela dei diritti, avviando indagini e azioni legali necessarie per identificare i responsabili, mitigare i danni e prevenire futuri attacchi.

Possibili attaccanti del sistema

È fondamentale analizzare e comprendere i potenziali attaccanti che potrebbero cercare di compromettere il sistema, considerando le motivazioni e le risorse a loro disposizione.

- **Bob The Eavesdropper:** un avversario passivo che tenta di carpire le credenziali private degli utenti mentre tentano di connettersi ad un servizio; possiede risorse computazionali medie.
- **Alice The Impersonator:** avversario attivo il cui obiettivo è accedere ai servizi utilizzando delle credenziali non valide per scopi illegali; possiede risorse computazionali medie.
- **Frank The Fraudster:** avversario attivo in possesso di CIE falsa con lo scopo di ottenere una credenziale valida per accedere ai servizi; è in possesso di dispositivi in grado di creare CIE false.
- **Jack The Rogue Server:** avversario attivo che si spaccia per un server onesto con l'obiettivo di utilizzare le informazioni ricevute dagli utenti per scopi malevoli come l'utilizzo improprio o la vendita a terzi, violando la privacy dell'utente; possiede risorse computazionali non trascurabili, possibilmente anche un data center.
- **Mary The Thief:** avversario attivo il cui obiettivo è rubare l'identità CIE di un utente onesto per scopi nefasti; possiede risorse computazionali medie.
- **George The Manipulator:** avversario attivo il cui obiettivo è quello di manipolare le credenziali dell'utente che ne ha fatto richiesta, agendo sul canale di comunicazione tra l'utente e l'autorità; possiede risorse computazionali che gli permettono di effettuare l'attacco man-in-the-middle.
- **Eve The Conspiracist:** avversario attivo complottista che si oppone all'innovazione e alle nuove tecnologie il cui scopo è provare che il sistema è una violazione della privacy ed è un pericolo per le persone; possiede risorse computazionali medie.
- **The Trickster's crew:** una combriccola di attaccanti disonesti che vogliono minare la reputazione della nostra organizzazione sfruttando le loro risorse condivise per effettuare attacchi DoS al nostro sistema, impedendone l'uso normale da parte degli utenti onesti; la potenza computazionale di questo gruppo è molto rilevante e potrebbe causare grandi problemi per un sistema non preparato.

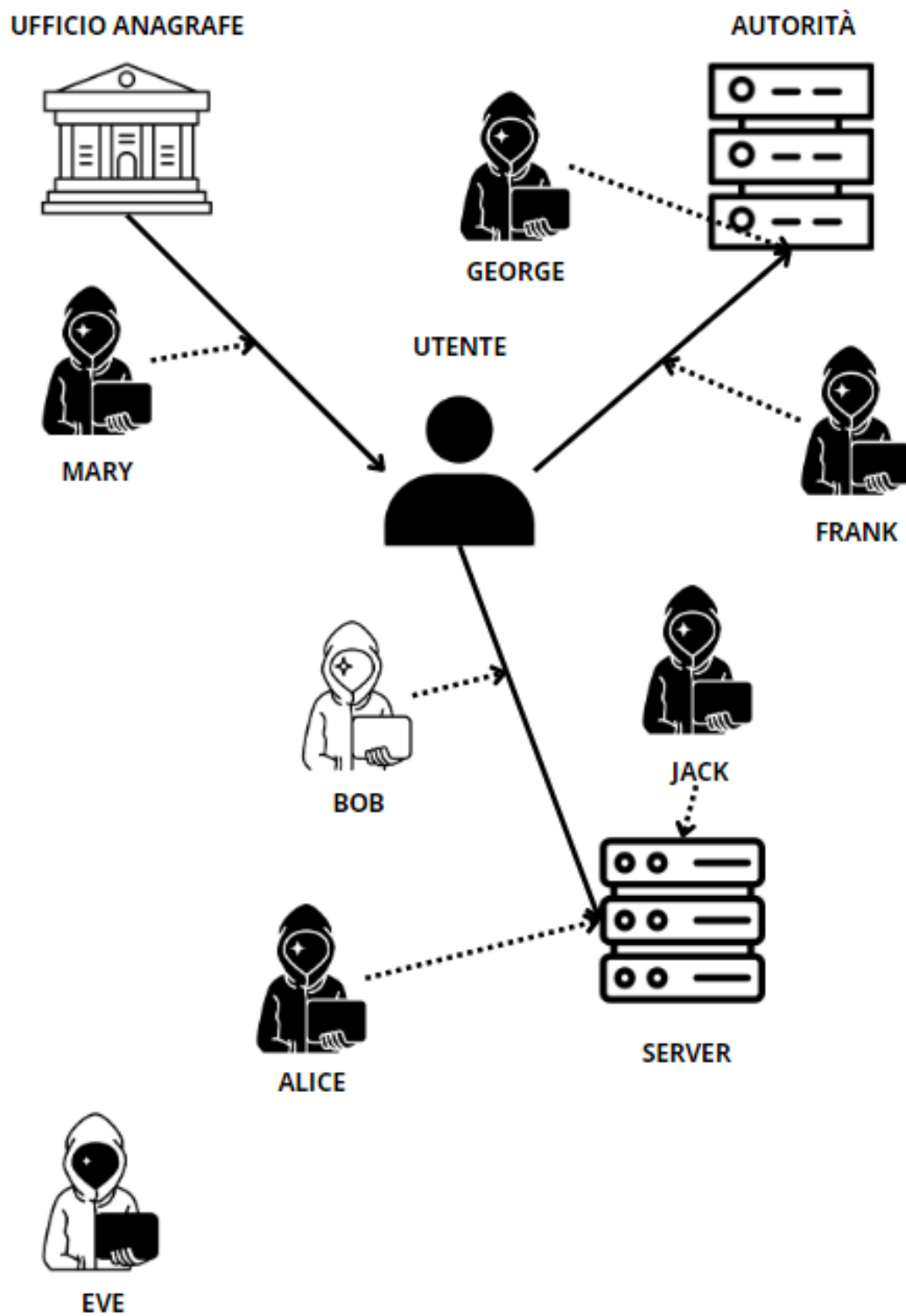


Figura 1: Schema sul posizionamento degli avversari

Proprietà

Vengono di seguito esaminate le principali proprietà che il sistema deve possedere per garantire un ambiente sicuro, affidabile e performante. Le proprietà saranno analizzate in base ai quattro pilastri fondamentali: confidenzialità, integrità, trasparenza ed efficienza.

Confidenzialità:

Secondo tale proprietà i dati sensibili dovrebbero restare confidenziali anche in presenza di attacchi. Quindi, garantisce che solo le persone autorizzate possano accedere alle informazioni, impedendo che dati critici vengano divulgati o esposti a terzi non autorizzati, anche durante tentativi di intrusione o compromissione del sistema.

1. i dati degli utenti presenti nelle credenziali devono essere protetti, ovvero accessibili solo dalle parti autorizzate in maniera controllata.
2. garantire la privacy delle comunicazioni tra gli utenti e il server, in modo che non sia possibile carpire informazioni utili.
3. garantire la privacy delle comunicazioni tra gli utenti e l'autorità, in modo che non sia possibile carpire i dati personali dell'utente che richiede una credenziale e/o rubarla.
4. garantire che un utente malintenzionato non sia in grado di identificarsi in un altro utente per l'accesso ad un servizio sfruttando le credenziali.
5. le credenziali devono essere utilizzate in maniera sicura e, una volta verificate per l'autenticazione, non vengano conservate o memorizzate dal server per qualsiasi scopo.
6. garantire che un utente non sia in grado di richiedere una credenziale valida che contenga informazioni non correlate alla sua persona.

Integrità:

Questa proprietà garantisce che il sistema mantenga la funzionalità prevista anche in presenza di attacchi. Assicura che i dati non vengano alterati in modo non autorizzato e che le operazioni vengano eseguite correttamente, preservando l'accuratezza e la completezza delle informazioni, indipendentemente dalle minacce esterne.

1. le credenziali devono essere verificabili, ovvero deve essere possibile verificare da tutti che siano state rilasciate dall'autorità competente.
2. la CIE e il PIN devono essere verificabili, ovvero deve essere possibile verificare da tutti che siano state rilasciate dall'autorità competente.
3. garantire che la credenziale utilizzata sia effettivamente riconducibile all'utente che la utilizza.

Trasparenza:

Il sistema non dovrebbe basarsi su algoritmi segreti e la sua confidenzialità e integrità non dovrebbero dipendere da un uso eccessivo di parti ritenute fidate da tutti i partecipanti. Inoltre, la trasparenza implica la pubblicazione di algoritmi e procedure, in modo che tutti possano verificarne l'affidabilità e la correttezza.

1. il sistema di generazione delle credenziali deve utilizzare algoritmi e protocolli pubblicamente noti e disponibili, in modo che gli utenti possano verificare l'integrità delle credenziali, rendendo così difficile, per un utente malintenzionato, influenzare il processo di generazione senza essere scoperto.
2. il processo di verifica delle credenziali deve essere noto e verificabile da tutti.
3. il sistema deve garantire che il processo di generazione delle credenziali sia imparziale.

Efficienza:

Il sistema dovrebbe essere utilizzabile senza incorrere in eccessivi costi e ritardi. L'obiettivo è fornire un'esperienza ottimale che consenta agli utenti di completare le loro attività con il minimo sforzo e senza incontrare difficoltà tecniche o finanziarie significative.

1. garantire che la generazione delle credenziali sia eseguita in modo rapido ed efficiente, riducendo al minimo l'impatto sulle prestazioni del sistema e l'esperienza degli utenti.
2. garantire che la verifica della legittimità della CIE sia eseguita in modo rapido ed efficiente, riducendo al minimo l'impatto sulle prestazioni del sistema e sull'esperienza degli utenti.
3. l'identificazione presso un servizio digitale tramite credenziali deve avvenire in modo semplice e rapido.

Completeness:

La completezza si riferisce al comportamento del sistema quando tutte le parti coinvolte operano in modo onesto e seguono le procedure stabilite. In queste circostanze il sistema è in grado di svolgere efficacemente la sua funzione. La completezza implica che il sistema riesca a gestire correttamente tutte le operazioni previste e a fornire risultati accurati e attendibili quando tutte le condizioni sono soddisfatte e tutte le parti agiscono in buona fede.

In particolare:

- se l'utente ha effettivamente fatto richiesta all'autorità competente, con la propria CIE, riceverà una credenziale valida.
- se l'utente è in possesso di una credenziale valida può accedere ai servizi.

WP2: SOLUZIONE

In questa sezione, verrà mostrata la presentazione di una soluzione che risponde al modello identificato nel WP1. L'obiettivo è quello di proporre un sistema che riesca a raggiungere un ragionevole compromesso tra efficienza, trasparenza, confidenzialità e sicurezza.

Panoramica generale di funzionamento

Il processo di acquisizione delle credenziali inizia con la richiesta e la successiva creazione delle stesse. Un individuo interessato a ottenere una credenziale si rivolge a un'autorità competente per il rilascio di tali documenti. L'utente presenta alla suddetta autorità la propria Carta d'Identità Elettronica (CIE), ricevuta insieme al PIN dall'Ufficio Anagrafe. La validità della CIE viene verificata, e in seguito viene rilasciata la credenziale richiesta. È importante notare che questa operazione di emissione avviene una sola volta e una volta completata, l'autorità competente non è più coinvolta nel processo.

Dopo aver ottenuto una credenziale valida, l'utente chiede l'accesso a servizi qualificati facendo richiesta al server, il quale, accertatosi della validità delle credenziali, permette all'utente di usufruire dei servizi in modo sicuro e affidabile.

Generazione e utilizzo delle credenziali

Nella presente sezione, svilupperemo un protocollo per la generazione di una credenziale e come viene impiegata nell'accesso a servizi digitali. Questo processo coinvolge come attori chiave: l'utente, l'autorità e il server dei servizi qualificati.

In questo protocollo, gli utenti interagiscono con l'autorità per la richiesta e generazione delle credenziali e con il server per usufruire dei servizi offerti. Andremo ad analizzare dapprima il modo con cui un utente interessato a ricevere una credenziale possa farne richiesta all'autorità, chiarendo il processo di rilascio.

Andremo a delineare il contenuto e la struttura delle credenziali affinché questo possa essere utilizzato come strumento digitale valido per l'identificazione e l'accesso ad un servizio digitale. Analizzeremo, infine, un possibile processo di identificazione ed accesso ad un servizio digitale.

Supposizioni

Alla base del funzionamento del protocollo proposto, si suppone che l'utente si sia recato personalmente in un Ufficio Anagrafe. Qui, a seguito della richiesta di una Carta d'Identità Elettronica (CIE), l'utente viene identificato attraverso un documento d'identità valido, come il codice fiscale. Gli operatori dell'ufficio provvedono quindi a trasmettere i dati anagrafici dell'utente ai database delle autorità, verificandone la veridicità tramite le informazioni presenti nell'anagrafe nazionale.

Supponiamo inoltre che:

- il server dell'autorità sia una parte fidata. Questa fiducia ci consente di presumere che le credenziali emesse contengano informazioni corrette e che il procedimento di rilascio, così come la struttura delle credenziali, siano perfettamente in accordo con il protocollo descritto di seguito.
- L'autorità abbia reso pubbliche tutte le informazioni necessarie alla verifica delle credenziali, inclusi gli algoritmi e i protocolli utilizzati. Questo implica che la struttura delle credenziali, il procedimento di rilascio e quello di identificazione siano accessibili a chiunque. Ciò garantisce la trasparenza del sistema e permette a qualsiasi parte interessata di verificare l'autenticità delle credenziali.
- affidandoci all'infrastruttura a chiave pubblica (PKI) già esistente, supponiamo che il server dell'autorità, a cui l'utente si collega per richiedere il rilascio delle credenziali, possieda un certificato valido rilasciato da una Certification Authority. Questo certificato viene utilizzato appositamente per firmare le credenziali rilasciate. Inoltre, il server deve avere un certificato valido per eseguire il protocollo TLS, necessario per instaurare una comunicazione sicura con l'utente.

Procediamo adesso con l'analisi dettagliata di quanto delineato fino a questo momento.

Richiesta firma digitale alla CIE

Quando l'utente decide di interrogare la CIE per ottenere una firma, viene instaurata una connessione TLS tra quest'ultimo e la CIE.

Viene a questo punto eseguito il seguente protocollo:

1. L'utente inizia una richiesta di connessione TLS con la CIE.
2. La CIE risponde con un messaggio contenente il proprio certificato digitale (X509v3, rilasciato da IPZS). Questo certificato contiene la chiave pubblica della CIE e viene firmato dall'IPZS.
3. L'utente verifica il certificato controllando la firma digitale e la catena di fiducia fino ad una Certification Authority fidata. Fatto ciò, genera una chiave di sessione simmetrica, tramite l'algoritmo $\text{Gen}(1^n)$, la cifra con la chiave pubblica della CIE e la invia.
4. La CIE decifra la chiave di sessione con la propria chiave privata.

In questo modo entrambi le parti possiedono la stessa chiave di sessione simmetrica che verrà utilizzata per cifrare e decifrare i dati trasmessi.

5. L'utente prepara la query $\text{SIGN}(\text{pin}, \text{hash})$ dove il pin è una stringa di 10 cifre che autentica l'utente mentre hash, che ha un valore di 256 bit, rappresenta lo SHA256 del messaggio m che l'utente desidera firmare. Una volta preparata la query, l'utente invia la query alla CIE.
6. La CIE verifica la query dell'utente controllando se il pin inviato corrisponde a quello memorizzato internamente e genera la firma digitale utilizzando la propria chiave segreta se il pin è corretto. Fatto questo, la CIE invia la firma ECDSA σ_{CIE} all'utente.

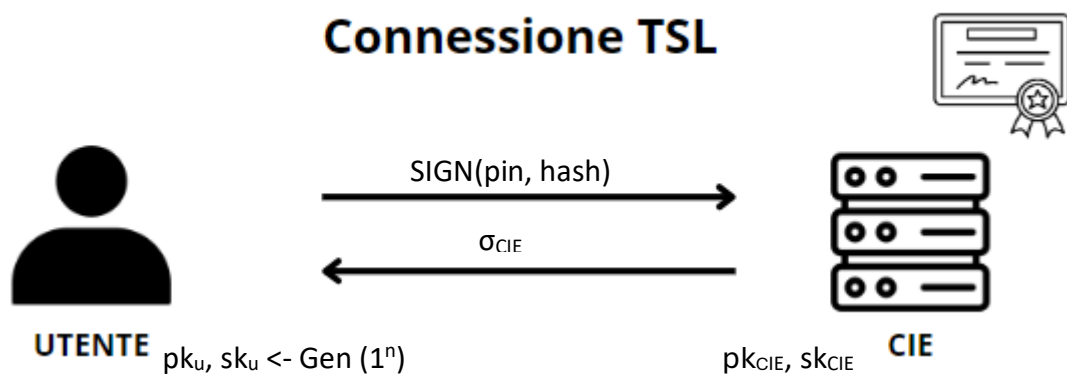


Figura 2

Algoritmi utilizzati:

- **Gen(1^n)**: utilizzato dall'utente per la generazione della coppia di chiavi pubbliche e private. Tramite questo algoritmo, viene istanziato il problema del logaritmo discreto ottenendo le seguenti informazioni: G (gruppo di ordine q), q (numero di elementi del gruppo), g (generatore del gruppo). In questo modo è possibile selezionare un certo valore $x \in \mathbb{Z}_q$ e calcolare $y = g^x$. La chiave pubblica, indicata con p_k è: (G, q, g, y) . La chiave privata, indicata con s_k : (G, q, g, x) . Si noti che la dimensione in termini di bit degli elementi dipende dal parametro di sicurezza 1^n .

Richiesta credenziali ad un'autorità

Quando l'utente decide di fare richiesta di una credenziale ad un'autorità, viene instaurata una connessione TLS tra quest'ultimo e l'autorità.

Viene a questo punto eseguito il seguente protocollo:

1. L'utente invia la richiesta della credenziale contenente:
 - La firma ECDSA ricevuta dalla CIE in modo che l'autorità ne riconosca l'identità.
 - La chiave pubblica p_{k_u} generata con l'algoritmo $\text{Gen}(1^n)$.
2. L'autorità riceve le informazioni contenute nella richiesta dell'utente e:
 - Verifica la validità della firma ECDSA, se non è valida il processo viene terminato
 - Genera la credenziale e la firma con σ_{CR} per garantirne l'autenticità e la invia all'utente.

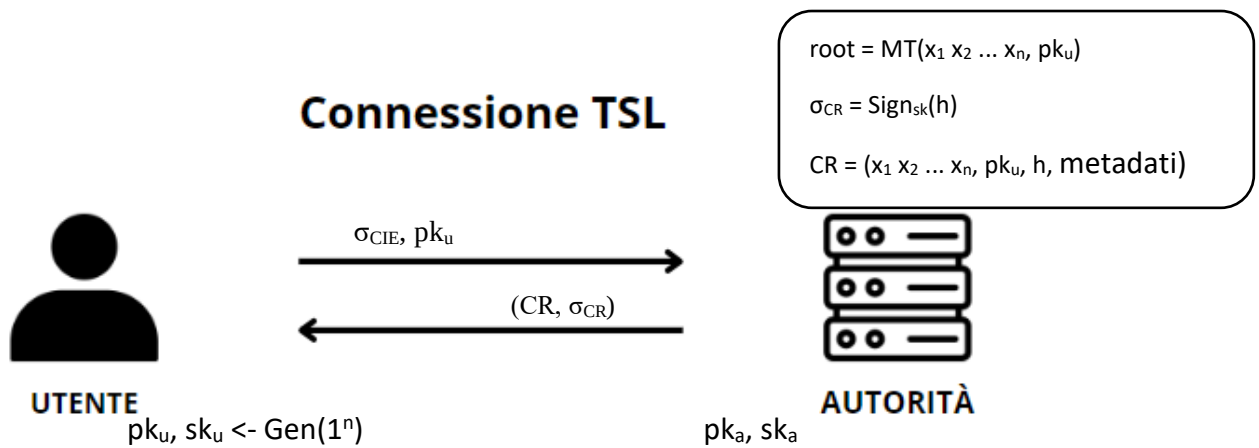


Figura 3

Generazione delle credenziali

Per generare le credenziali l'autorità utilizza un Merkle Tree alimentato dai dati delle credenziali e dal contributo personale dell'utente, ovvero la chiave pubblica pk_u . Tale chiave consente di generare un documento digitale dipendente da un'informazione segreta (chiave privata) posseduta solo dall'utente. All'interno del Merkle Tree, quanto appena affermato viene indicato come:

$$MT(x_1 x_2 \dots x_n, pk_u)$$

Una volta ottenuto il valore h rappresentativo dell'intera struttura dell'albero, l'autorità procede con l'applicarvi una firma digitale σ_{CR} tramite l'algoritmo $\text{Sign}_{sk}(h)$. Questo assicura che la credenziale sia stata effettivamente rilasciata dall'autorità.

A questo punto, per verificare che una certa credenziale x_i sia parte della struttura identificata da $root$, sarà sufficiente corredare x_i con gli hash necessari al calcolo di $root$ a partire dalla foglia x_i . Una volta calcolata e firmata h , insieme a tutti gli hash intermedi che vanno a costruire il Merkle Tree, questi vengono salvati all'interno del documento ed entrano a far parte di quella categoria di informazioni che verranno chiamati metadati.

La credenziale sarà quindi costituita nel modo seguente:

$$CR = (x_1 x_2 \dots x_n, pk_u, \text{metadati})$$

Quindi, la credenziale e la firma verranno inviate all'utente tramite il canale di comunicazione sicuro instaurato dalle due parti.

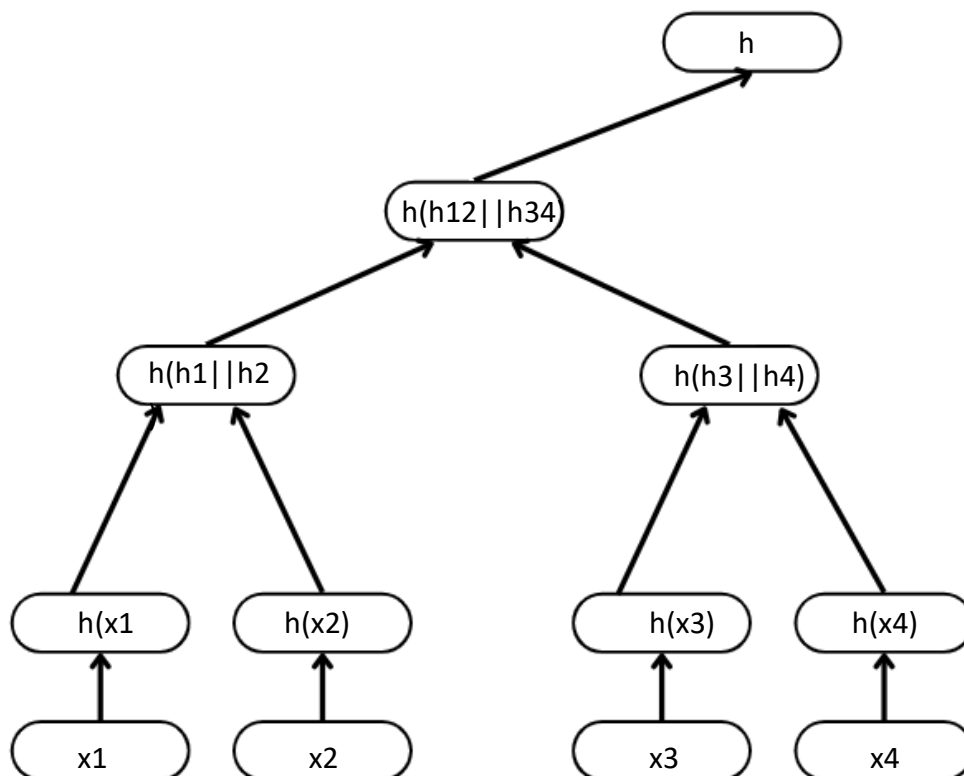


Figura 4: Struttura parziale del Merkle Tree

Algoritmi utilizzati:

- **Gen(1^n)**: utilizzato dall'utente per la generazione della coppia di chiavi pubbliche e private. Tramite questo algoritmo, viene istanziato il problema del logaritmo discreto ottenendo le seguenti informazioni: G (gruppo di ordine q), q (numero di elementi del gruppo), g (generatore del gruppo). In questo modo è possibile selezionare un certo valore $x \in \mathbb{Z}_q$ e calcolare $y = g^x$. La chiave pubblica, indicata con p_k è: (G, q, g, y) . La chiave privata, indicata con s_k : (G, q, g, x) . Si noti che la dimensione in termini di bit degli elementi dipende dal parametro di sicurezza 1^n .
- **MT**: funzione che restituisce l'intera struttura del Merkle Tree associato ad una serie di dati in chiaro. Ogni hash che va a rappresentare i nodi di tale albero è ottenuto tramite l'applicazione della funzione SHA256.
- **Sign $_{s_k}$** : è un algoritmo di firma digitale dello schema di firma di Schnorr. L'algoritmo, a partire da un messaggio m ed una chiave privata s_k , restituisce una coppia (z, a) che è stata indicata con σ in cui:
 - a rappresenta un contributo casuale del gruppo tale che $a = g^r$, con $r \in \mathbb{Z}_q$
 - $z = r + H(y||a||m)x$. $H(\cdot)$ è un random oracle ed è implementato con SHA256.

Richiesta di un servizio generico da parte dell'utente

L'utente inizia una connessione TLS con il server fornitore del servizio qualificato tramite un messaggio che contiene la lista delle versioni TLS supportate dal client, il set di algoritmi supportati e una stringa di random bytes. Il server risponde con un messaggio contenente il suo certificato SSL, il set di algoritmi da lui scelto e una stringa di random bytes. L'utente verifica il certificato SSL del server con la Certification Authority che l'ha rilasciato in modo da confermare l'identità del server e invia un'ulteriore stringa di random bytes criptata con la chiave pubblica del server, ottenuta dal suo certificato SSL. Tale stringa può essere decriptata solo con la chiave privata del server. Una volta che il server decrypta la stringa, il client e il server generano chiavi di sessioni a partire dalle tre stringhe casuali che sono state inviate durante l'handshake SSL. Le chiavi di sessione generate verranno utilizzate per il resto della comunicazione.

Una volta stabilita la connessione sicura, nel momento in cui l'utente richiede l'accesso al servizio offerto dal server, il server comunica quali sono le credenziali richieste per accedere al servizio e richiede inoltre che l'utente dimostri che le credenziali fornite gli appartengano. A tale richiesta, l'utente risponde con:

- la sua chiave pubblica pk_u , usata dall'autorità per generare il Merkle Tree delle credenziali e tutti i metadati necessari alla verifica di $root$, radice del Merkle tree, oltre che la Merkle proof associata alla pk_u .
- le credenziali codificate come una sequenza di bit firmate con σ_{CR} dall'autorità che le ha rilasciate.
- certificato SSL di quest'ultima.

Il server verifica che le credenziali x_i inviate dall'utente sono quelle richieste e calcola h a partire da pk_u e Merkle proof inviate dall'utente. Tramite algoritmo $Vrfy_{pk}(h, \sigma_{CR})$ il server verifica l'autenticità delle credenziali.

La funzione $Vrfy_{pk}(h, \sigma_{CR}) : \{0, 1\}$ verifica, sulla base della conoscenza della chiave pubblica del firmatario, che σ sia una firma valida per h , verificando che $g^z = ay^c$.

Verifica che l'autorità che le ha rilasciate sia affidabile a partire dal certificato SSL della stessa, nello stesso modo in cui il client aveva verificato l'identità del server nella fase di handshake.

Il server deve quindi verificare che le credenziali presentate dall'utente gli appartengono, per fare questo ricordiamo che il server ha accesso alla pk_u usata per generare il Merkle Tree delle credenziali. Quindi, all'utente basta dimostrare che conosce la chiave privata sk_u corrispondente alla pk_u per dimostrare che quelle credenziali gli appartengono.

Si procede quindi tramite protocollo di Schnorr, in cui l'utente ricopre il ruolo di prover, mentre il server il ruolo di verifier:

- L'utente sceglie un valore casuale $r \in \mathbb{Z}_q$;
- L'utente calcola il valore $a = g^r$ e lo invia al server;

- Il server sceglie un valore $c \in \mathbb{Z}_q$ e lo invia all'utente;
- L'utente calcola il valore $z = r + c * sk_u$, con $z \in \mathbb{Z}_q$, e lo invia al server;
- Infine, il server verifica che $g^z = a(pk_u)^c$.

Se questa verifica ha esito positivo, allora l'utente ha dimostrato di conoscere la sk_u corrispondente alla pk_u e che quindi è il possessore delle credenziali mostrate.

Nel caso le credenziali richieste siano più di una, il server verifica che le pk_u associate siano uguali in modo da verificare che appartengono tutte alla stessa persona, evitando quindi che più utenti possano combinare le loro credenziali per ottenere l'accesso al servizio.

In caso di esito positivo di tutte le verifiche, il server consente all'utente di accedere al servizio, in caso negativo nega l'accesso.

Tale soluzione non consente all'utente di verificare le azioni svolte dal server e individuare possibili comportamenti disonesti da parte di questo. In particolare, il server potrebbe negare all'utente l'uso del servizio nonostante l'utente abbia presentato le credenziali valide richieste. Inoltre, il server potrebbe garantire l'accesso a user non in possesso delle credenziali richieste.

SECONDA PARTE

Nome e Cognome	WP responsabile
Palma Orlando	WP3 e WP4

WP3: ANALISI

In questa sezione verrà approfondita e valutata la soluzione proposta nel WP2, mettendola in relazione con le proprietà fondamentali di confidenzialità, integrità, trasparenza ed efficienza, così come sono state delineate e analizzate nel WP1. Questo esame critico mira a determinare in che misura la soluzione proposta rispetta e soddisfa i requisiti essenziali emersi nel WP1, fornendo una comprensione più completa del suo potenziale e delle sue implicazioni.

Confidenzialità

Di seguito viene condotta un'analisi approfondita degli avversari che rappresentano una minaccia per la confidenzialità del sistema. L'obiettivo è identificare e comprendere i diversi attori malevoli e le loro tattiche, al fine di valutare l'impatto potenziale delle loro azioni sul sistema e proporre contromisure efficaci per mitigare i rischi associati.

- **Bob the Eavesdropper:** questo avversario è in ascolto sul canale di comunicazione nella speranza di ottenere informazioni utili che possano essere raccolte e/o vendute. Essendo i canali di comunicazione fra utente e server dei servizi protetti da un canale sicuro TLS, questo avversario non è in grado di raccogliere alcuna informazione utile.
- **Alice The Impersonator:** questo avversario attacca l'accesso da parte di un utente al server dei servizi digitali tramite un attacco attivo di tipo man in the middle con l'obiettivo di rubare una credenziale valida ed utilizzarlo per i propri scopi. Tuttavia, la presenza di un canale TLS rende impossibile tale attacco. Anche nel caso in cui Alice fosse in possesso di tale documento non riuscirebbe comunque ad utilizzarlo per i propri scopi non essendo in grado di dimostrare ad un Verifier di essere il possessore del documento.
- **Frank The Fraudster:** questo avversario attacca l'autorità richiedendo una credenziale poiché è in possesso di una CIE e di una firma ECDSA false. L'attacco è destinato a fallire in quanto l'autorità si accerta dell'autenticità del richiedente tramite la firma ECDSA. Ma, nel caso in cui la firma ECDSA utilizzata dall'avversario sia presente nel database delle firme autentiche, l'attacco andrebbe a buon fine. Questo scenario però non verrà approfondito in quanto ci viene garantito che l'Ufficio Anagrafe e l'IPZS eseguono onestamente i loro task.
- **Jack The Rogue Server:** questo avversario attacca la confidenzialità delle informazioni presenti all'interno delle credenziali essendo in grado di accedere ai dati presenti all'interno del server dei servizi digitali in fase di accesso di un utente ad uno dei servizi. Tale avversario potrebbe collezionare i dati inviati dall'utente per venderli con scopi illeciti. Tali dati sono inviati su un canale sicuro ma ad un server fraudolento, quindi saranno visibili in chiaro dall'avversario.
- **Mary The Thief:** questo avversario ha lo scopo di rubare l'identità CIE di un utente. Tale attacco non può essere sventato dal sistema progettato in quanto il rilascio della CIE è affidata all'Ufficio Anagrafe, la quale si affida alla Giustizia per risolvere tali problematiche.
- **George The Manipulator:** questo avversario attacca la richiesta da parte di un utente all'autorità tramite un attacco attivo di tipo man in the middle con l'obiettivo di

rubare una firma ECDSA valida ed utilizzarla per i propri scopi. Il suo attacco non va a buon fine in quanto la connessione dei giocatori al server avviene tramite il protocollo TLS il quale è resiliente ad attacchi di tipo man in the middle.

Di seguito vengono analizzate le proprietà espresse nel WP1:

La prima proprietà è garantita dal fatto che, grazie alla modalità di rappresentazione delle credenziali, l'utente può condividere in chiaro solo le informazioni selezionate, con la certezza che tali dati saranno accessibili esclusivamente alla parte autorizzata. La seconda e la terza proprietà sono assicurate dall'utilizzo di un canale di comunicazione basato su TLS, sia nella comunicazione tra l'utente e l'autorità, sia tra l'utente e il server dei servizi digitali. La quarta proprietà è protetta, a meno che l'utente non decida volontariamente di cedere o vendere la propria chiave privata, associata alla chiave pubblica presente nelle credenziali. In questi casi, i meccanismi digitali possono intervenire solo parzialmente: se l'utente non cede volontariamente la propria chiave privata, può richiedere una revoca; tuttavia, se la chiave viene ceduta volontariamente, non è possibile alcun intervento. Infine, la quinta proprietà è rispettata poiché l'unica informazione che rimane completamente sconosciuta, anche a un server malevolo, è quella legata alla chiave segreta in possesso dell'utente, che rimane completamente anonima. Questo è reso possibile grazie all'impiego di una zero-knowledge proof nell'ambito dello schema di identificazione di Schnorr, utilizzato nella fase di identificazione. L'ultima proprietà è garantita dalla possibilità di verificare direttamente l'identità del richiedente, grazie all'utilizzo della firma digitale. La prova dell'identità avviene tramite l'ufficio anagrafe, che rilascia la CIE garantendo l'esecuzione onesta dei propri compiti.

Integrità

Di seguito viene condotta un'analisi approfondita degli avversari che rappresentano una minaccia per l'integrità del sistema. L'obiettivo è identificare e comprendere i diversi attori malevoli e le loro tattiche, al fine di valutare l'impatto potenziale delle loro azioni sul sistema e proporre contromisure efficaci per mitigare i rischi associati.

- **Alice The Impersonator:** questo avversario è sconfitto in quanto, a fronte della richiesta di una Zero Knowledge Proof per l'identificazione con le credenziali, non è in grado di completare il protocollo non essendo a conoscenza della chiave privata generata insieme alla chiave pubblica presente all'interno delle credenziali rubate.
- **George The Manipulator:** poiché TLS garantisce un tunnel sicuro all'interno della rete, l'avversario non è in grado di minare l'integrità del sistema di generazione delle credenziali non potendo in alcun modo influenzare i messaggi inviati sul canale.
- **The Trickster's crew:** questo avversario potrebbe minare l'integrità del sistema decidendo di bombardare il server dei servizi digitali con milioni di messaggi indesiderati in modo da causare il blocco dei computer alle richieste di dati in entrata. Questo attacco compromette la connessione TLS perché la connessione potrebbe non riuscire a stabilirsi correttamente o potrebbe essere estremamente lenta. Ciò compromette la fase di handshake SSL, in cui il server invia il certificato SSL e

vengono generate le chiavi di sessione. Senza una connessione sicura, non è possibile procedere con la verifica delle credenziali dell'utente. Anche se la connessione TLS viene stabilita, l'attacco potrebbe impedire al server di eseguire le operazioni necessarie per la verifica delle credenziali dell'utente. Il server potrebbe non essere in grado di elaborare le Merkle proof, calcolare i valori richiesti per il protocollo di Schnorr, o verificare la firma digitale con l'algoritmo Vrfy_pk. Di conseguenza, l'accesso al servizio potrebbe essere negato anche a utenti legittimi. Inoltre, in situazioni di sovraccarico, il server potrebbe anche generare errori nei log di verifica.

Di seguito vengono analizzate le proprietà espresse nel WP1:

La prima proprietà è garantita dalla presenza di un'unica firma digitale apposta dall'autorità sfruttando una specifica chiave pubblica, pubblicamente nota. Si è inoltre supposto che l'autorità (che è una parte fidata) abbia rilasciato pubblicamente la procedura con cui le credenziali vengono costruite e come vengano firmate. La seconda proprietà è garantita in quanto è possibile verificare da tutti che la CIE e il PIN sono rilasciate dall'Ufficio Anagrafe che è ritenuta un'autorità fidata universalmente. La terza proprietà viene garantita dalla presenza di una connessione sicura TLS e a un processo di verifica. L'utente dimostra di possedere la chiave privata associata alla chiave pubblica utilizzata per generare le credenziali tramite il protocollo di Schnorr. Il server verifica l'autenticità delle credenziali e assicura che tutte le credenziali presentate appartengano alla stessa persona.

Trasparenza

Il sistema progettato è orientato alla trasparenza grazie a vari elementi chiave:

- Il sistema utilizza una connessione TLS per garantire una comunicazione sicura e autentica, verificando i certificati SSL per confermare l'identità delle entità coinvolte.
- Gli algoritmi utilizzati, come ECDSA per la firma digitale e il protocollo Schnorr per la verifica delle credenziali, sono pubblici e consultabili da chiunque. Questo garantisce che ogni passo del processo sia verificabile e trasparente.
- L'uso di un Merkle Tree per gestire le credenziali offre un metodo trasparente e verificabile per assicurare l'integrità dei dati.
- Il protocollo di Schnorr permette di verificare che l'utente sia il legittimo proprietario delle credenziali, garantendo accesso solo agli utenti autorizzati e mantenendo sicurezza e trasparenza.

Di seguito vengono analizzate le proprietà espresse nel WP1:

Le prime due proprietà vengono garantite poiché non si fa affidamento su autorità di terze parti o strumenti poco chiari e il processo di generazione e verifica delle credenziali è reso noto pubblicamente. La terza proprietà viene garantita grazie all'utilizzo di firme digitali e verifiche incrociate in modo da ottenere un sistema che garantisce imparzialità nel processo di generazione. L'uso delle firme digitali, sia lato server che lato utente per ogni comunicazione effettuata, garantisce che tutti siano in grado di verificare l'autenticità delle informazioni scambiate.

Efficienza

Di seguito vengono analizzate le proprietà espresse nel WP1:

La prima proprietà viene garantita in quanto il sistema utilizza un protocollo di crittografia avanzato e un Merkle Tree per la gestione delle credenziali. Questi strumenti sono noti per la loro efficienza in termini di computazione, specialmente quando implementati su hardware adeguati. Tuttavia, la complessità dei calcoli necessari, come la generazione delle chiavi pubbliche/private e la firma digitale, potrebbe richiedere risorse computazionali significative. La seconda proprietà è verificata poiché la verifica della legittimità della CIE si basa sull'uso di certificati digitali (certificato X509v3), che sono standardizzati e ottimizzati per operazioni rapide di autenticazione. Questa fase include la verifica della catena di fiducia del certificato, un processo ampiamente ottimizzato. Infine, anche la terza proprietà è garantita visto che l'identificazione attraverso l'uso di credenziali digitali, utilizzando il protocollo di Schnorr, è progettata per essere sicura e relativamente veloce.

Grafico Radar

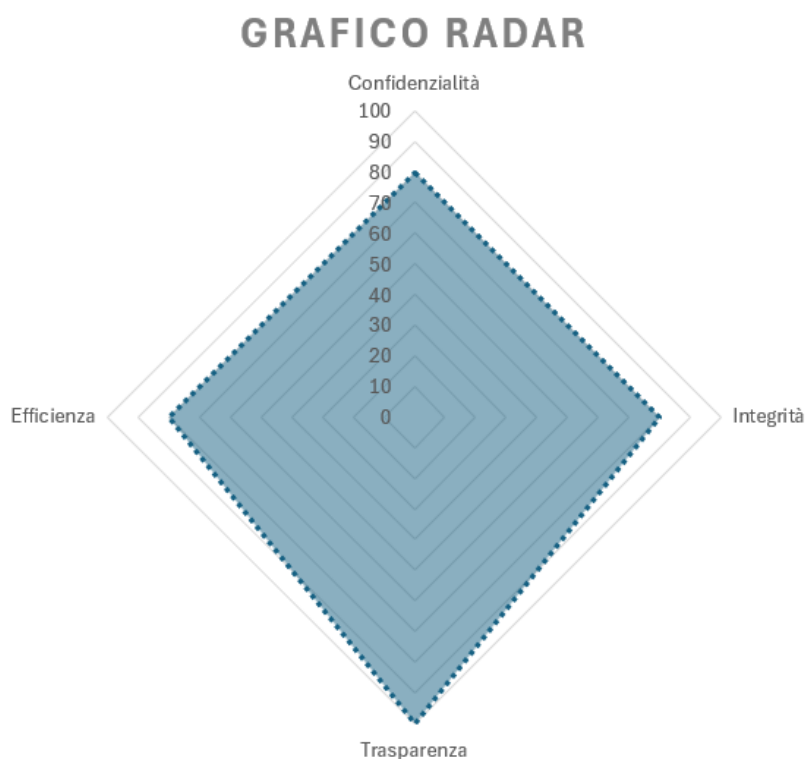


Figura 5: Grafico a radar rappresentante le prestazioni del sistema

WP4: IMPLEMENTAZIONE E PRESTAZIONI

L'implementazione pratica di quanto discusso nel Capitolo 2 è stata realizzata interamente in Python. *Purtroppo, l'implementazione non è stata completata ma di seguito verrà descritta l'ideologia con cui si stava proseguendo nell'implementazione.*

Per realizzare le comunicazioni tra utenti e i diversi server coinvolti nei protocolli proposti, ho scelto di utilizzare una struttura basata su oggetti. In questo contesto, le parti coinvolte sono rappresentate mediante istanze di oggetti di classi specifiche. Tramite la chiamata dei metodi messi a disposizione dalle interfacce degli oggetti coinvolti nelle comunicazioni, si è emulata l'interazione tra due applicativi in esecuzione su macchine diverse e connesse tramite la rete internet. Sono state sviluppate due classi principali:

- **User:** questa classe rappresenta gli utenti che desiderano collegarsi ad un server. Ogni utente possiede e gestisce tutte le informazioni necessarie per stabilire una connessione sicura con il server.
- **Server:** questa classe costituisce una base per le classi derivate ServerAuthority e ServerService. La classe ServerAuthority modella il comportamento del server dell'autorità che si occupa di rilasciare le credenziali, mentre ServerService gestisce le operazioni relative all'utilizzo dei servizi digitali.

Vi sono poi altre classi:

- **MerkleTree:** questa classe è stata implementata per generare le credenziali, come descritto nel WP". La classe implementa un albero binario gestito in accordo con le specifiche di un Merkle Tree. In particolare, questa classe presenta:
 - Foglie: rappresentano i diversi dati memorizzati, e ad ogni foglia è associato un hash ottenuto applicando la funzione crittografica SHA256.
 - Radice (Root): rappresenta l'intero Merkle Tree, ossia l'hash della radice dell'albero, ottenuto combinando gli hash delle foglie e dei nodi intermedi secondo un algoritmo di concatenazione sicuro.
 - Nodi interni: rappresentano gli hash intermedi, calcolati combinando gli hash delle loro foglie figlie.
- **CIE:** questa classe contiene un metodo `sign` che firma dei dati utilizzando una chiave privata, ma solo se viene fornito il PIN corretto, che è `0000`. Se il PIN è corretto, i dati vengono scritti in un file, firmati con la chiave privata tramite OpenSSL, e la firma viene restituita. Se il PIN è errato, il programma stampa un messaggio di errore e si interrompe.